

IT-Sicherheit

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Übersicht Netzwerk-Sicherheit

- Einführung
- Bedrohungen
- Werkzeuge der Angreifer und zur Analyse,
- Sicherheitsmaßnahmen (Schwerpunkt im Netzwerk)
 - Organisatorisch
 - Verschlüsselung
 - Erkennung/Verfolgung
 - Weitere Informationen

Bedrohungen im Netzwerk - Schutzziele

- (1) (Daten-) Integrität (integrity)
- (2) (Informations-) Vertraulichkeit (confidentiality)
- (3) Verfügbarkeit (availability)
- (4) Verbindlichkeit, Nachweisbarkeit (non-repudiation),
Zurechenbarkeit (accountability)
- (5) Authentizität von Subjekten, Objekten
(authenticity)
- (6) Privatheit (privacy), Anonymität (anonymity),
Pseudonymität (pseudonymity)
- Bereits betrachtet:
Was ist das? Wie geht's?
- Genauer: Bemerken? Verhindern?

Bedrohungen im Netzwerk – (1) Integrität

- Was ist das?
- Wie kann das passieren?
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (1) Integrität

- Was ist das?
 - Daten werden bei der Übertragung unautorisiert und unbemerkt modifiziert
 - Regel, wer darf was mit welchen Daten tun
- Wie kann das passieren?
 - Jeder dazwischen kann Änderungen an den Daten vornehmen
 - Technische Unzulänglichkeiten (schwache Signale)
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (1) Integrität

- Was ist das?
 - Daten werden bei der Übertragung unautorisiert und unbemerkt modifiziert
 - Regel, wer darf was mit welchen Daten tun
- Wie kann das passieren?
 - Jeder dazwischen kann Änderungen an den Daten vornehmen
 - Technische Unzulänglichkeiten (schwache Signale)
- Wie kann ich es bemerken?
 - Crc, Hashwert, Signatur
- Wie kann ich es verhindern?
 - Kein Zugang von außen! Also nicht zu 100%!
 - Schutz am Netzeingang - Firewall

Bedrohungen im Netzwerk – (2) Vertraulichkeit

- Was ist das?
- Wie kann das passieren?
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (2) Vertraulichkeit

- Was ist das?
 - Unautorisiert Informationen gewinnen.
 - Daten und Metainformation sind interessant.
 - Regeln wer darf was sehen.
- Wie kann das passieren?
 - Protokollieren/Sniffen der Daten -> s. Folie
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (2) Vertraulichkeit

- Was ist das?
 - Unautorisiert Informationen gewinnen.
 - Daten und Metainformation sind interessant.
 - Regeln wer darf was sehen.
- Wie kann das passieren?
 - Protokollieren/Sniffen der Daten -> s. Folie
- Wie kann ich es bemerken?
 - Gar nicht!
 - Kontrolle der gesamten Infrastruktur
- Wie kann ich es verhindern?
 - Definierter Weg über zuverlässige Netzknoten
 - Verschlüsselung (AnwendungsV, TLS, IPsec, s.Folien)

Bedrohungen im Netzwerk – (3) Verfügbarkeit

- Was ist das?
- Wie kann das passieren?
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (3) Verfügbarkeit

- Was ist das?
 - Funktionalität/Benutzbarkeit beeinträchtigt
- Wie kann das passieren?
 - Überlast, Sabotage, DOS, DDOS (s. Folie)
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (3) Verfügbarkeit

- Was ist das?
 - Funktionalität/Benutzbarkeit beeinträchtigt
- Wie kann das passieren?
 - Überlast, Sabotage, DOS, DDOS (s. Folie)
- Wie kann ich es bemerken?
 - Ist meist offensichtlich
- Wie kann ich es verhindern?
 - Ressourcen großzügig.
 - Anfragefrequenz begrenzen
 - Netz separieren Intern/extern/Abteilungen, QOS
 - Problem Unterscheidbarkeit berechtigter/unberechtigter Zugriff

Bedrohungen im Netz – (4) Verbindlichkeit, Nachweisbarkeit

- Was ist das?
- Wie kann das passieren?
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netz – (4) Verbindlichkeit, Nachweisbarkeit

- Was ist das?
 - Durchgeführte Handlungen nicht abstreitbar
- Wie kann das passieren?
 - „Ich war's nicht“, nicht meine Mail, Bestellung....
Malware in der Mail.
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netz – (4) Verbindlichkeit, Nachweisbarkeit

- Was ist das?
 - Durchgeführte Handlungen nicht abstreitbar
- Wie kann das passieren?
 - „Ich war's nicht“, nicht meine Mail, Bestellung....
Malware in der Mail.
- Wie kann ich es bemerken?
 - Inkonsistenter Kontext.
- Wie kann ich es verhindern?
 - Signatur, unterschiedliche Anforderungen, je nach erforderlicher (Rechts-)Verbindlichkeit
 - Beweise sichern, protokollieren (Forensik)
 - Problem Zeitaufwand

Bedrohungen im Netzwerk – (5) Authentizität von Subj, Obj

- Was ist das?
- Wie kann das passieren?
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (5) Authentizität von Subj, Obj

- Was ist das?
 - Echtheit der Identifikation von Subjekten und Objekten durch: PWD, Schlüssel, Biometrie, Smartcards
- Wie kann das passieren?
 - PWD ausgespäht, gecrackt, (s. 2.Teil)
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (5) Authentizität von Subj, Obj

- Was ist das?
 - Echtheit der Identifikation von Subjekten und Objekten durch: PWD, Schlüssel, Biometrie, Smartcards
- Wie kann das passieren?
 - PWD ausgespäht, gecrackt, (s. 2.Teil)
- Wie kann ich es bemerken?
 - Kontext inkonsistent
- Wie kann ich es verhindern?
 - Bessere Verfahren, mehrere unabhängige Identifikationen, Sperren von Karten, Austausch von Schlössern

Bedrohungen im Netzwerk – (6) Privatheit, Anonymität

- Was ist das?
- Wie kann das passieren?
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (6) Privatheit, Anonymität

- Was ist das?
 - Schutz der personenbezogenen Daten, Recht auf Informationelle Selbstbestimmung
- Wie kann das passieren?
 - Zugriff auf Daten nicht ausreichend geschützt.
 - Weiterverkauf für Werbungszwecke
 - Logfiles speichern alles (z.B. Moodle)
- Wie kann ich es bemerken?
- Wie kann ich es verhindern?

Bedrohungen im Netzwerk – (6) Privatheit, Anonymität

- Was ist das?
 - Schutz der personenbezogenen Daten, Recht auf Informationelle Selbstbestimmung
- Wie kann das passieren?
 - Zugriff auf Daten nicht ausreichend geschützt.
 - Weiterverkauf für Werbungszwecke
 - Logfiles speichern alles (z.B. Moodle)
- Wie kann ich es bemerken?
 - Daten tauchen in anderem Zusammenhang auf
- Wie kann ich es verhindern?
 - rechtlich: Datenschutzgesetze, Zweckbindung von Datensammlungen
 - Pseudonyme: Id kennt nur „Notar“
 - Metadaten?

Netzwerksicherheit – Weiterführendes aus den Zielen

- Integrität – Schutz durch Firewall
 - Aufbau, Funktionsweise von Firewalls.
- Vertraulichkeit – Protokollieren/Sniffen
- Vertraulichkeit – Verschlüsselung
 - Wie im Netz organisieren (Key Exchange)
- Verfügbarkeit – Schutz vor DOS/DDOS durch Firewall
- Verbindlichkeit/Nachweisbarkeit – Forensik
- Authentizität – Vertrauen in Passworte
 - Passwort-Crack (rainbow-tables)
- Verletzung der Schutzziele durch Schwachstellen
 - Erkennen und Beheben (Konfig und Update)
- Systeme sicher konstruieren, Sicherheit prüfen.

Netzwerksicherheit – Sniffen

Daten werden nur protokolliert, analysiert, aber nicht verändert.

- Wo abgreifen:
 - Kabel/Faser/Funk (z.B. Tempora)
 - Schicht 2 – Netzwerkkarte, eigener Datenverkehr
 - Management Port am Switch, eigenes LAN
 - Spoofing, eigenes LAN (s. Folie)
 - Protokoll im Router/Switch, Route im Internet (s. Folie)
 - Proxy
- Werkzeuge
 - Diverse, Wireshark

Netzwerksicherheit – Sniffen Werkzeuge Wireshark

- Mächtiges Werkzeug zur Protokollanalyse
- > 2220 Protokolle werden unterstützt (Computerbild).
- Transparente Darstellung der Protokollschichten
- Aufgabe:
 - Wireshark installieren, eigenen Datenverkehr aufzeichnen
 - Werden (meine) Passwörter im Klartext übertragen?
 - Pop3 ??
 - Internet-Shops??
 - Finden Sie drei Beispiele für verschlüsselte Übertragung und drei für eine Klartext-Übertragung und geben Sie dafür eine Alternative an.

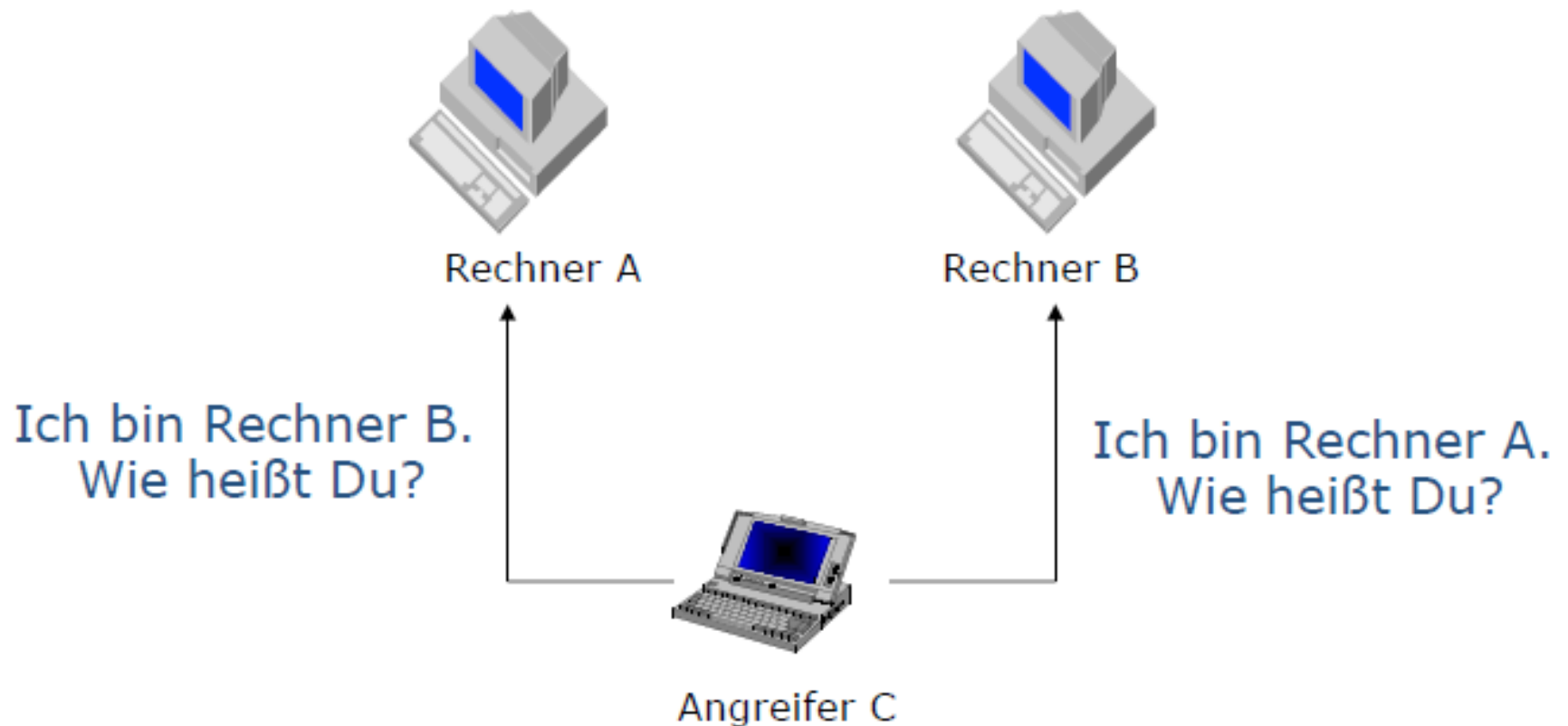
Netzwerksicherheit – Sniffen Werkzeuge Spoofing

- „Problem“: Daten sind nicht in Reichweite.
 - LAN: ARP-Spoofing
 - IP:
 - Source Routing (Option im IP-Paket)
 - Falsche Absenderadresse (für DOS, DDOS)
 - Routing Tables Spoofing
 - <https://www.zdnet.com/article/bgp-spoofing-why-nothing-on-the-internet-is-actually-secure/>
 - <https://www.heise.de/newsticker/meldung/Router-luegen-nicht-was-wenn-doch-200283.html>
 - BGP-Routing: <https://www.youtube.com/watch?v=IzLPKuAOe50>,
<https://www.youtube.com/watch?v=t7ilZxXFYYQ>
 - Aktueller: <https://www.manrs.org/2020/04/not-just-another-bgp-hijack/>
 - Aktuell: <https://www.youtube.com/watch?v=u7fig13eW4Q>
 - DNS Spoofing
 - Gefälschte DNS-Server-Einträge (DNSChanger 2007-2011, 2012)
 - s. Folie

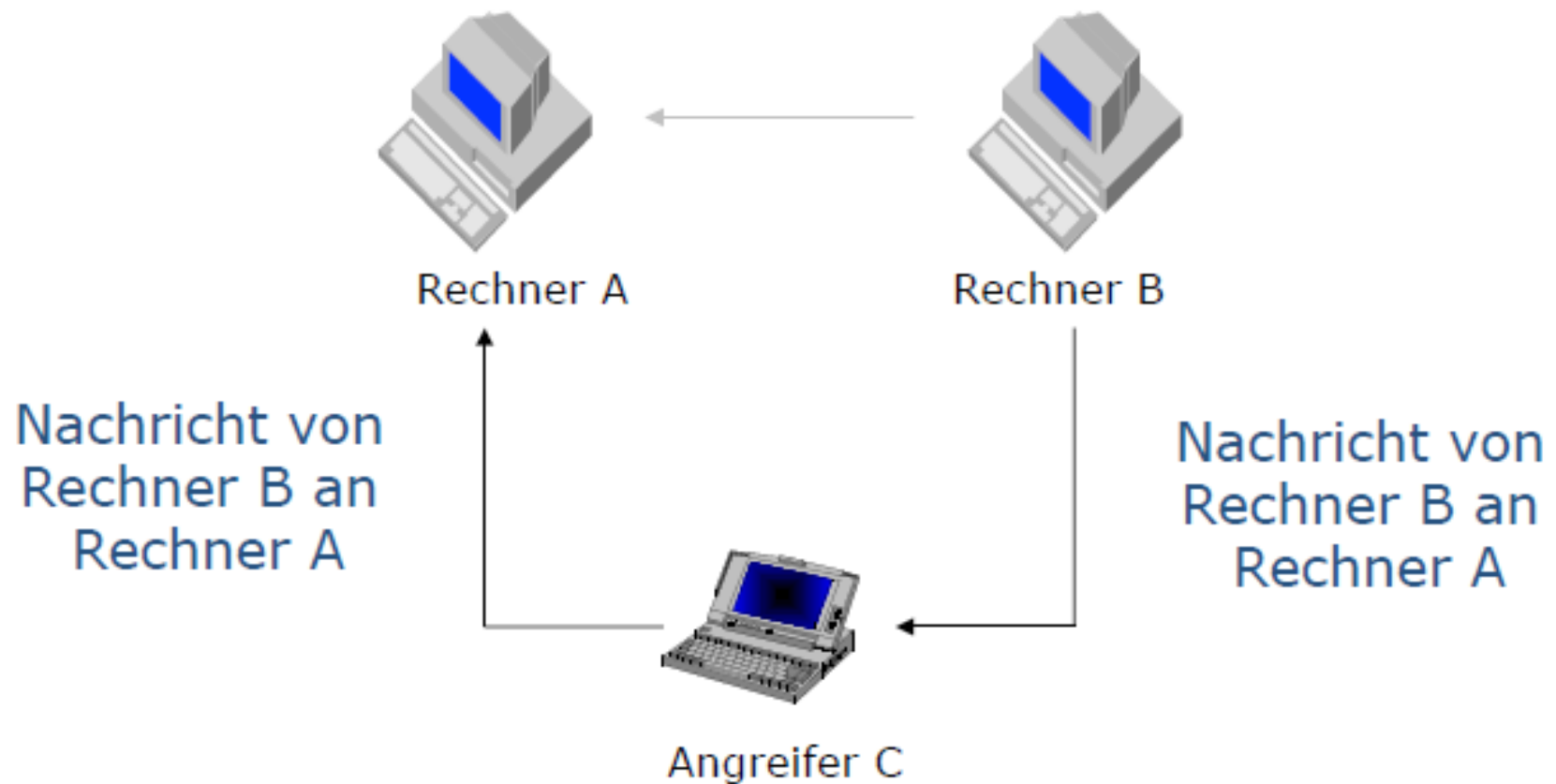
Netzwerksicherheit – Routing Table Spoofing

- Zu sehr im Detail, aber immer relevant.
- <https://www.manrs.org/2022/07/for-12-hours-was-part-of-apple-engineerings-network-hijacked-by-russias-rostelecom/>
Russia's Rostelecom started announcing routes for part of Apple's network.
- Mutually Agreed Norms for Routing Security (MANRS)
<https://www.manrs.org/>

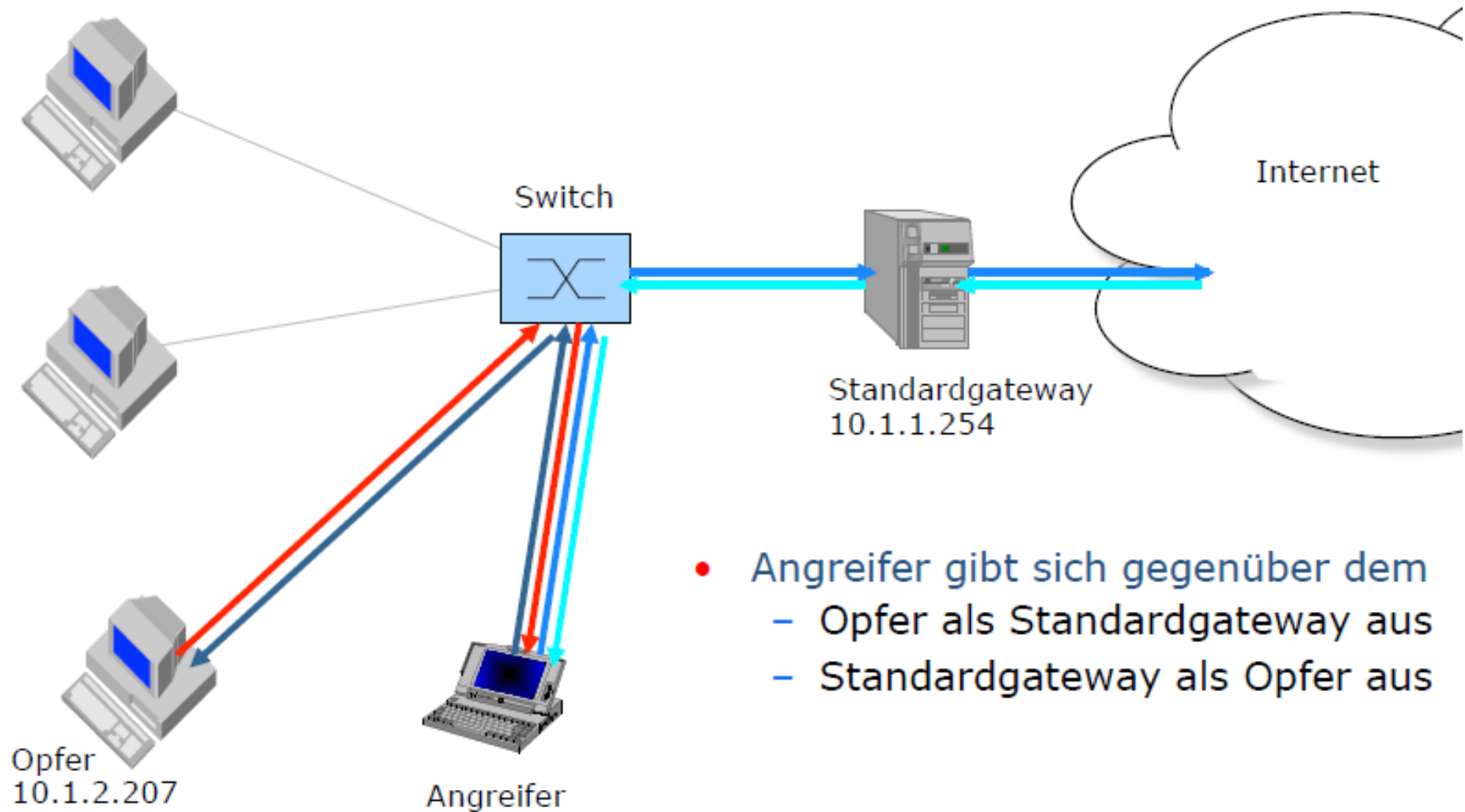
Netzwerksicherheit – Sniffen Werkzeuge ARP Spoofing I



Netzwerksicherheit – Sniffen Werkzeuge ARP Spoofing II

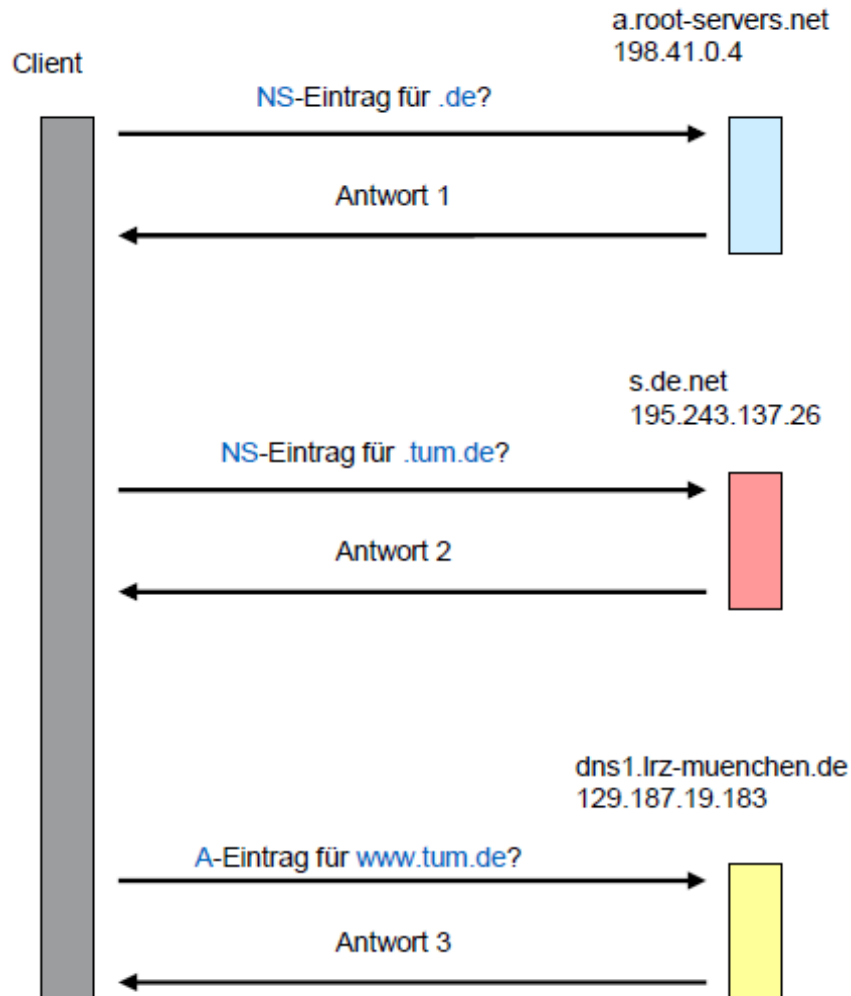


Netzwerksicherheit – Sniffen Werkzeuge ARP Spoofing II



Netzwerksicherheit DNS

- **Beispiel:** Auflösung von `www.tum.de` in IP-Adresse



Antwort 1

```
:: AUTHORITY SECTION:  
de.      IN  NS  a.nic.de.  
de.      IN  NS  c.de.net.  
de.      IN  NS  f.nic.de.  
de.      IN  NS  l.de.net.  
de.      IN  NS  s.de.net.  
de.      IN  NS  z.nic.de.
```

Zuständige
Nameserver

```
:: ADDITIONAL SECTION:  
a.nic.de. IN  A  194.0.0.53  
c.de.net. IN  A  208.48.81.43  
f.nic.de. IN  A  81.91.164.5  
l.de.net. IN  A  77.67.63.105  
s.de.net. IN  A  195.243.137.26  
z.nic.de. IN  A  194.246.96.1
```

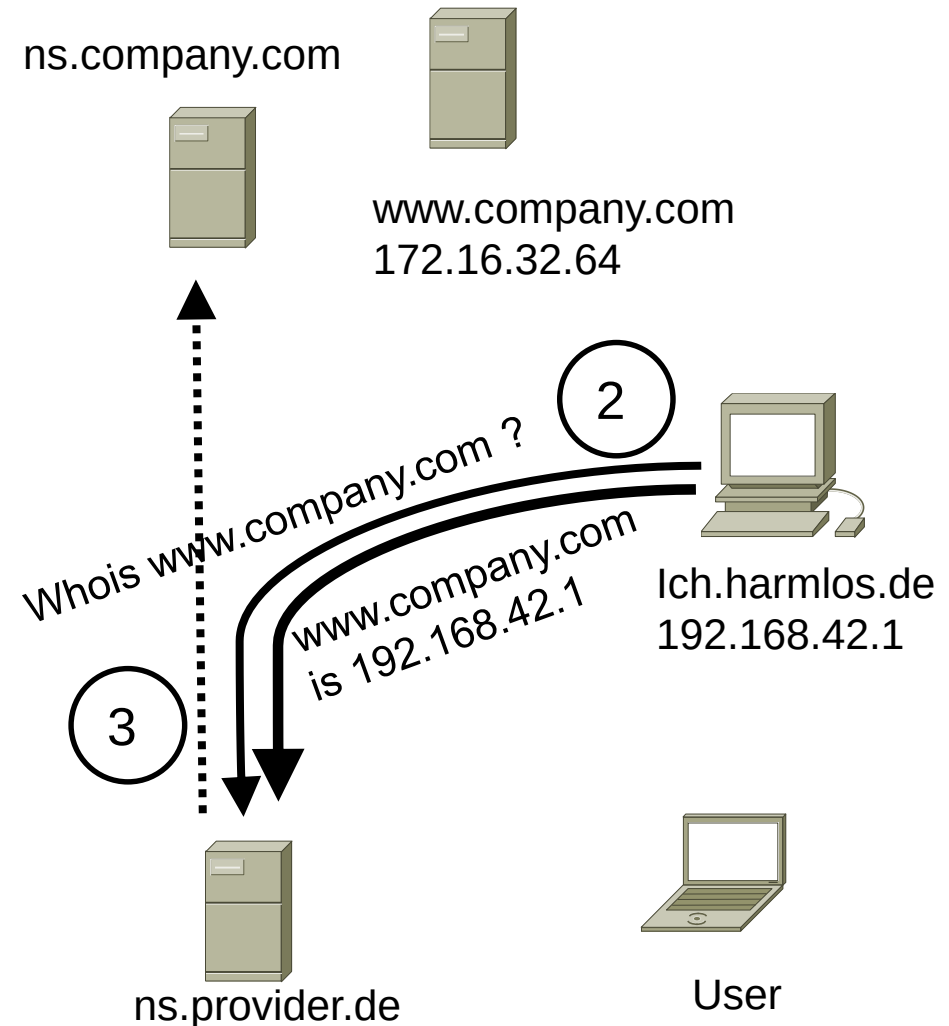
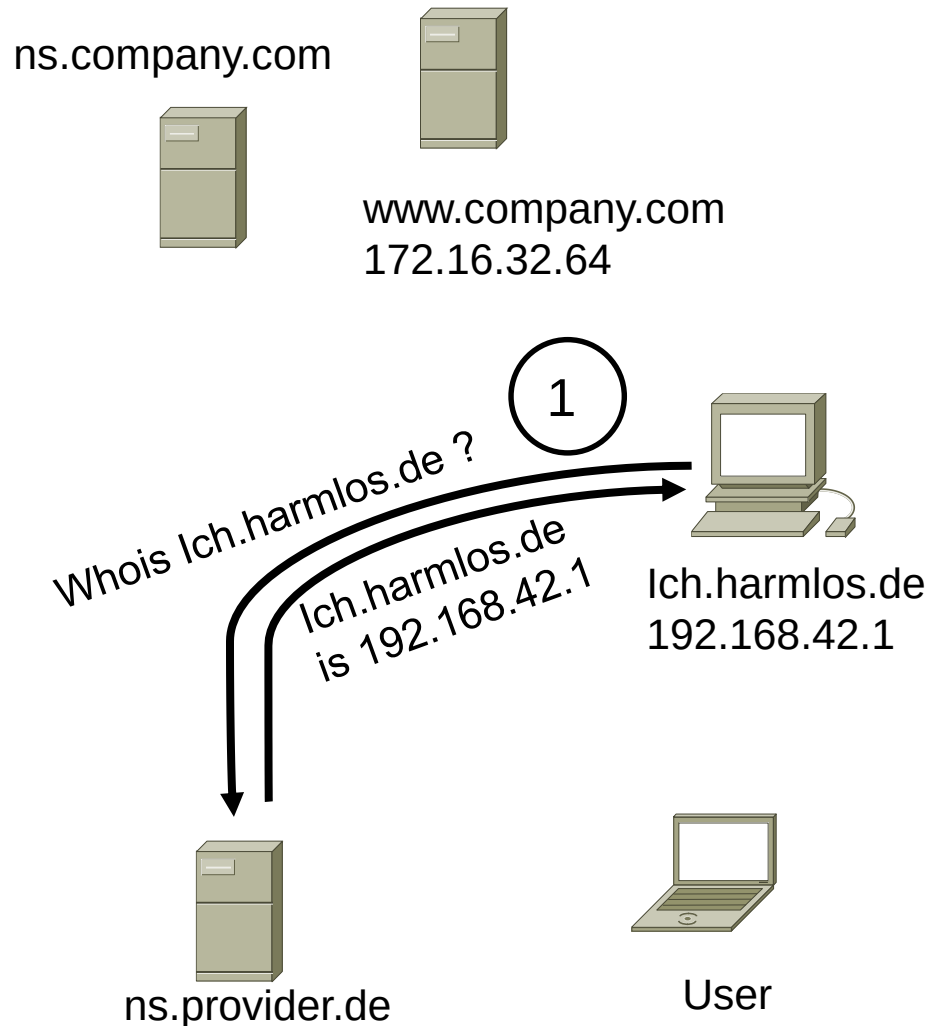
Zugehörige
IP-Adressen

```
:: AUTHORITY SECTION:  
tum.de.  IN  NS  dns1.lrz-muenchen.de.  
tum.de.  IN  NS  dns3.lrz-muenchen.de.  
tum.de.  IN  NS  dns2.lrz-muenchen.de.
```

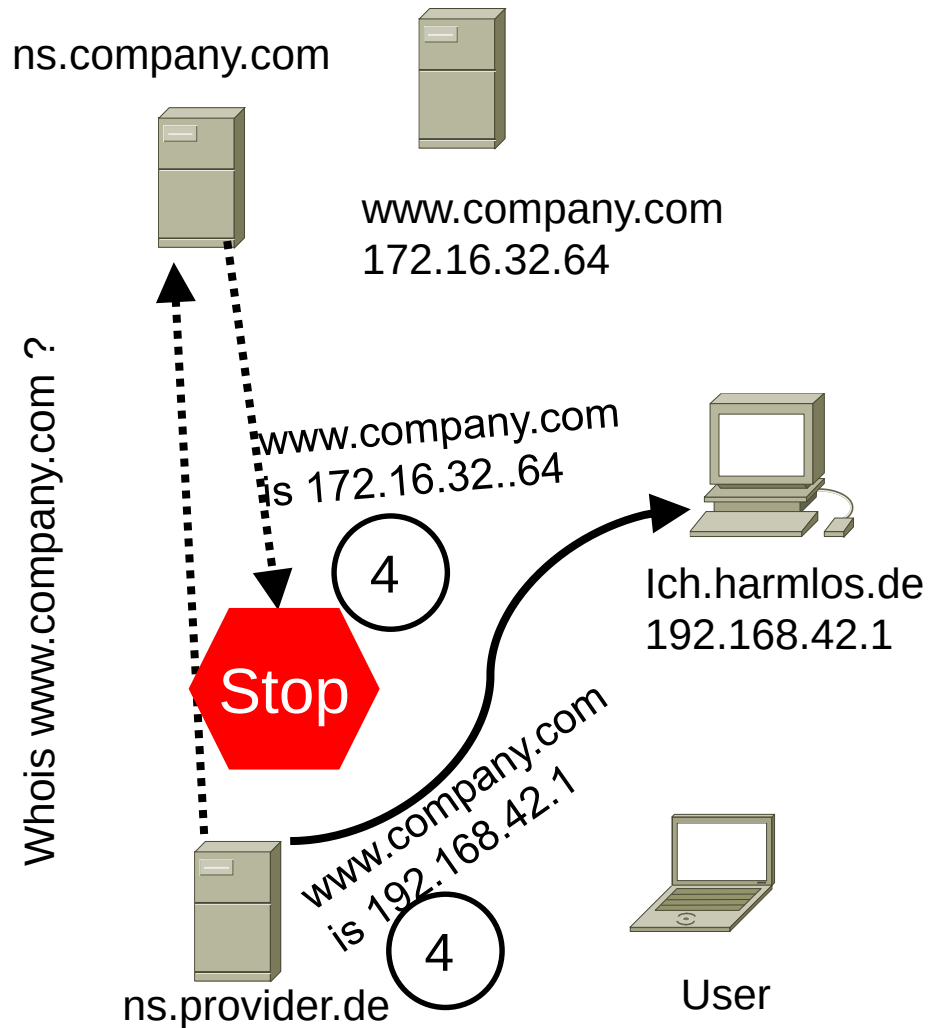
```
:: ADDITIONAL SECTION:  
dns1.lrz-muenchen.de. IN  A  129.187.19.183  
dns2.lrz-muenchen.de. IN  A  141.40.9.211  
dns3.lrz-muenchen.de. IN  A  193.136.2.123
```

```
:: ANSWER SECTION:  
www.tum.de.      IN  CNAME  tum.www.ze.tu-muenchen.de.  
tum.www.ze.tu-muenchen.de. IN  CNAME  tum.www.ze.tum.de.  
tum.www.ze.tum.de. IN  CNAME  portal.mytum.de.  
portal.mytum.de.  IN  A      129.187.39.3
```

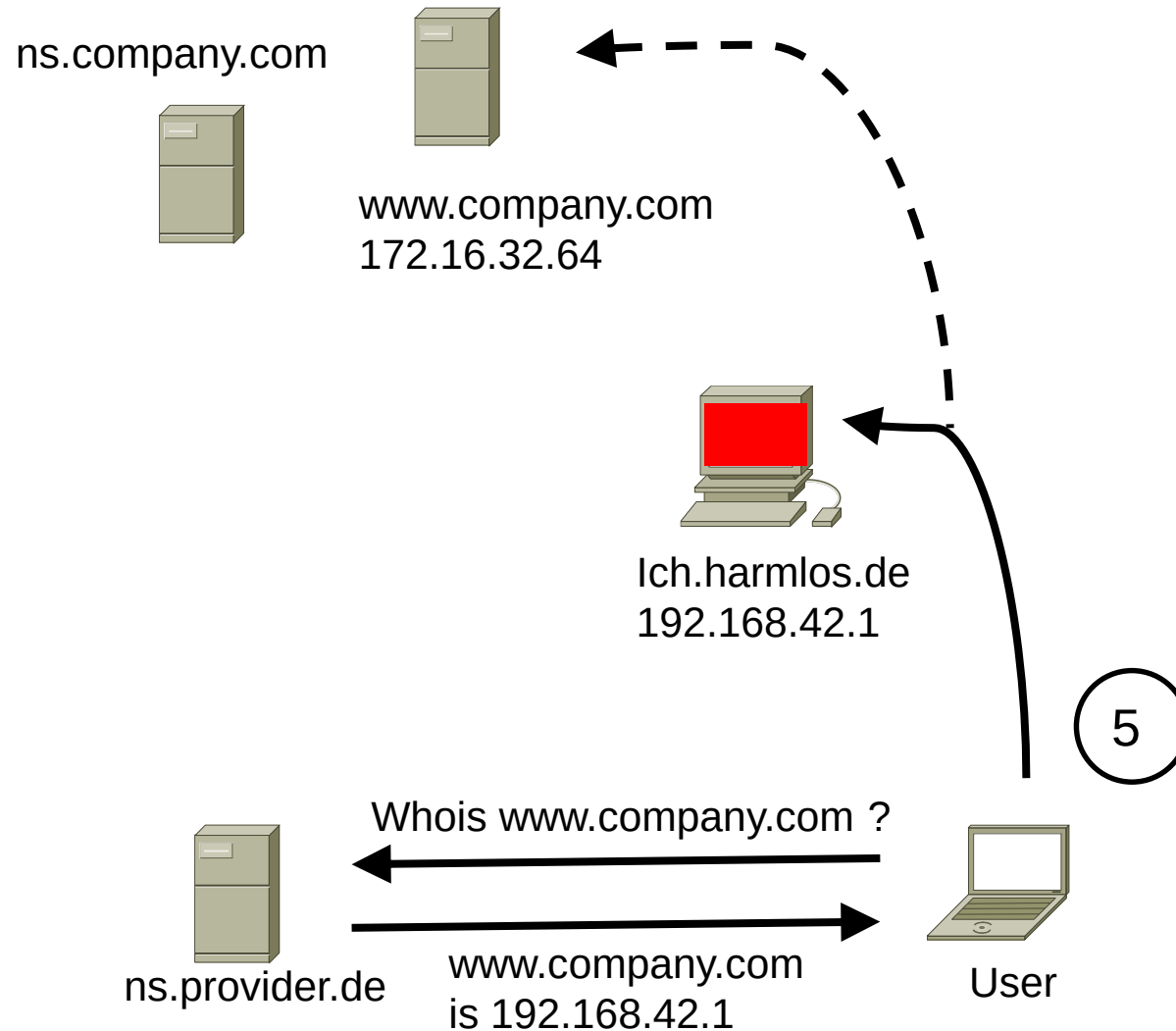
Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing



Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing



Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing



Netzwerksicherheit – Sniffen Werkzeuge DNS Spoofing

- 1. Der Angreifer stellt eine rekursive Anfrage nach seinem eigenen Rechner, um die aktuelle Query-ID zu ermitteln.*
- 2. Der Angreifer fragt nach `www.company.com` und schickt sofort gefälschte Antworten auf den Weg.*
- 3. Anfrage wird an den zuständigen Nameserver weitergereicht und sofort durch die gefälschten Pakete beantwortet.*
- 4. Die echte Antwort kommt zu spät und wird verworfen. Der Provider-Nameserver antwortet mit den gefälschten Informationen.*
- 5. Ein Anwender will auf '`www.company.com`' zugreifen und wird aufgrund der gefälschten Daten umgelenkt.*